Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 6. Seguridad de la información y gestión de riesgos

Índice

Esquema

Ideas clave

6.1. Introducción y objetivos

6.2. Seguridad de la información y gestión de riesgos

6.3. Política de Seguridad de la Información

6.4. Referencias bibliográficas

A fondo

Ciberseguridad. Una estrategia informático/militar

Ciberriesgos: un acercamiento desde la perspectiva del gestor de riesgos

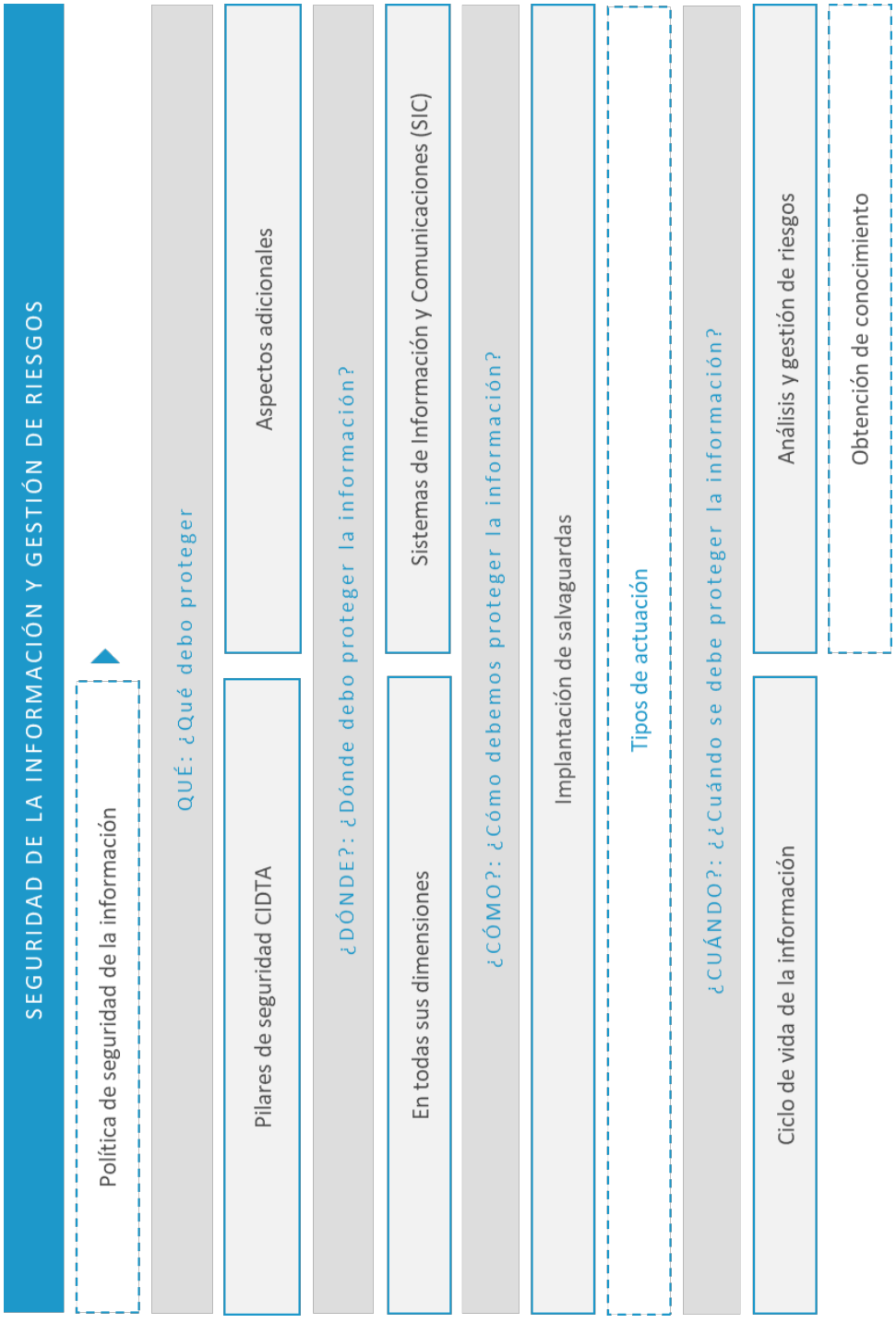
Política de seguridad de las TIC (CCN-STIC 001)

Glosario de términos de ciberseguridad: una guía de aproximación para el empresario

Managing Cyber Risk: A Handbook for UK Boards of Directors

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

6.1. Introducción y objetivos

El objetivo fundamental de esta unidad es comprender la importancia de la seguridad de la información, así como la necesidad de gestionar los riesgos como aspecto fundamental para alcanzar los objetivos de negocio de una Organización.

Este tema abordará distintas cuestiones relativas a aspectos generales de la seguridad de la información y la gestión de los riesgos a los que está expuesta la información.

Los principales objetivos de este tema son los siguientes:

- Repasar aspectos generales sobre seguridad de la información.
- Conocer aspectos generales sobre la gestión de riesgos.

© Universidad Internacional de La Rioja (UNIR)

6.2. Seguridad de la información y gestión de riesgos

Garantizar la **seguridad de la información** es uno de los objetivos prioritarios de cualquier organización, pues la información es uno de los activos más importantes con los que cuentan las organizaciones y siempre ha estado amenazada, ya desde la antigüedad se era consciente de la existencia de las **amenazas** a las que está expuesta la información y se utilizaban medios para protegerla. Prueba de ello es que Julio César ya cifraba sus mensajes con el conocido procedimiento que lleva su nombre, pero el auge en la implantación de las Tecnologías de la Información y las Comunicaciones (TIC) ha **incrementado** el número de amenazas a las que está expuesta, así como la probabilidad de materialización de dichas amenazas.

Para **proteger la información,** que en sí es algo inmaterial pero que reside en diferentes tipos de soportes -como pueden ser las personas, los documentos escritos o los sistemas informáticos-, es necesario tomar las medidas de seguridad apropiadas para garantizar el nivel de seguridad de la información que requiere una organización y así poder cumplir con sus **objetivos de negocio.**

La seguridad de la información debe formar parte de todos los procesos de negocio de una organización, tanto en el caso de los procesos manuales como automatizados, ya que en todos ellos interviene la **información de la organización** como parte fundamental, teniendo en cuenta además que dichos procesos involucran a personas, a tecnología y a relaciones con socios de negocios, clientes o terceros.

Para proteger adecuadamente la información de una organización, primero, hay que **dar respuesta a cuatro preguntas clave:** qué, dónde, cómo y cuándo.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Qué

Hay que garantizar el acceso, integridad, disponibilidad, autenticidad, confidencialidad, trazabilidad y conservación de la información de la organización.

Tradicionalmente se considera que la seguridad de la información consta de las siguientes **dimensiones de la seguridad:**

Confidencialidad	[C]
Integridad	[I]
Disponibilidad	[D]
Autenticidad	[A]
Trazabilidad	[T]

Tabla 1. Dimensiones de la seguridad. Fuente: elaboración propia.

Adicionalmente a estas cinco dimensiones es necesario tener en cuenta otros dos aspectos: garantizar el acceso y la conservación de la información, que pueden llegar a considerarse parte de la dimensión «disponibilidad», pero que es necesario tratar de forma específica por las características y peculiaridades de estos.

- **Confidencialidad:** es la garantía de que la información no es conocida por personas, organizaciones o procesos que no disponen de la autorización necesaria.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- **Integridad:** es la garantía de que la información no se ha transformado ni modificado de forma no autorizada durante su procesamiento, transporte o almacenamiento y que, además, permite detectar fácilmente las posibles modificaciones que pudieran haberse producido.

- **Disponibilidad:** es la garantía de que la información es accesible en el momento en el que los usuarios autorizados (personas, organizaciones o procesos) tienen necesidad de acceder a ella.

- **Autenticidad:** es la garantía de la identidad del usuario que origina una información. Permite conocer con certeza quién envía o genera una información específica.

- **Trazabilidad:** es la garantía de que en todo momento se podrá determinar quién hizo qué y en qué momento lo hizo.

- **Conservación de la información:** la conservación de la información no se debe tratar de forma independiente, ya que, junto con la utilización y acceso a la información, forma parte del ciclo de vida de esta. Es necesario contemplar todas las fases del ciclo de vida de la información, teniendo en cuenta las diferentes características de todos los tipos de soporte, tanto cuando este es el papel, como cuando el soporte es electrónico.
  La gestión de los dispositivos, de los soportes electrónicos y de los formatos utilizados debe realizarse por medio de procedimientos orientados a garantizar la conservación de la información, protegiendo a los soportes en los que reside del deterioro, daño, robo o acceso no autorizado. Estos procedimientos también deben contemplar los procedimientos de destrucción o reutilización de soportes, que son de aplicación cuando ha finalizado la vida útil de la información que contienen o la de los propios soportes.

© Universidad Internacional de La Rioja (UNIR)

- **Acceso:** por *acceso* se entiende la capacidad de poder utilizar los recursos de los sistemas de información y comunicaciones que nos permiten acceder a la información.

Dónde

La información es almacenada, procesada y transmitida por **los Sistemas de Información y Comunicaciones (SIC),** por lo tanto, para garantizar la seguridad en todas sus dimensiones y aspectos es necesario garantizar la seguridad de los Sistemas de Información y Comunicaciones de forma global.

Un Sistema de Información y Comunicaciones es un conjunto de elementos interrelacionados, personas, datos/información, procedimientos y recursos técnicos, dedicados al **proceso y gestión de la información** que una organización necesita para alcanzar sus objetivos de negocio.

Hay que proteger todos y cada uno de los elementos que forman parte del Sistema de Información y Comunicaciones de la organización frente a las amenazas a las que se encuentran expuestos, teniendo en cuenta sus **características y vulnerabilidades.**

Cómo

Deben contrarrestarse todas las amenazas a las que está expuesta la información de una organización por medio de la **implantación de salvaguardas (controles)** que pueden actuar de alguna de las siguientes maneras:

- Minimizando la probabilidad de la materialización de una amenaza.
- Disminuyendo el impacto en la organización, si no se ha podido evitar la materialización de una amenaza.
- Estableciendo procedimientos que permitan una recuperación rápida de los daños sufridos y una vuelta a la operativa normal.

© Universidad Internacional de La Rioja (UNIR)

- Utilizando mecanismos que permitan modificar las salvaguardas de acuerdo con la experiencia adquirida en los incidentes anteriores.

Cuándo

La información hay que protegerla durante todo su ciclo de vida, desde el momento en el que el dato entra en el sistema, hasta el momento en que deja de ser útil y se procede a su destrucción, pasando por todas las fases del ciclo de vida de la información, almacenamiento, proceso, transmisión y utilización.

Análisis y gestión de riesgos

Para que una organización pueda garantizar de forma adecuada la seguridad de uno de sus principales activos, la información, es necesario que **analice y gestione los riesgos** a los que está expuesta.

Para que una organización pueda conocer los riesgos a los que está expuesta debe **conocer el entorno,** tanto externo como interno, en el que desarrolla sus procesos de negocio. Para alcanzar este conocimiento deben estudiarse tanto las **fuentes externas,** que le aportarán información de riesgos generales, como las **fuentes internas,** que le van a permitir valorar el grado en el que los riesgos de carácter general le son de aplicación. Una de las fuentes internas más importantes es el **histórico de incidentes.**

Por medio del análisis de riesgos, una organización obtiene el conocimiento de a qué está expuesta, lo que le permitirá identificar los riesgos que le podrían impedir lograr sus objetivos de negocio, determinando su **magnitud** e identificando las **áreas** que requieran medidas de salvaguarda o controles en función del riesgo detectado.

El análisis de riesgos intenta que los criterios en los que se apoya la seguridad sean más objetivos, permitiendo a la organización gestionar sus riesgos y tomar decisiones en base a los riesgos propios.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Teniendo en cuenta que la mitigación total de los riesgos es imposible, la gestión de riesgos tiene como objetivo gestionar o tratar el riesgo **hasta disminuir el riesgo residual** a los niveles asumibles por la dirección y debe:

- Ser una parte integral de todos los procesos de negocio.
- Crear y proteger el valor.
- Formar parte de la toma de decisiones.
- Tratar explícitamente la incertidumbre.
- Ser sistemática, estructurada y oportuna.
- Estar basada en la mejor información posible.
- Ser adaptable.
- Integrar factores humanos y culturales.
- Ser transparente y participada por las partes interesadas de la organización.
- Ser dinámica, iterativa y responder a los cambios.
- Facilitar la mejora continua.

© Universidad Internacional de La Rioja (UNIR)

6.3. Política de Seguridad de la Información

La política de seguridad de la información recogerá las directrices y los principios de alto nivel que rigen las actividades de seguridad de la organización; al igual que, los objetivos y responsabilidades que se demandarán a los diferentes participantes en la gestión de la seguridad de la información.

Una política de seguridad, como declaración de principios de la organización, debe plasmar las directrices generales y principios de actuación que seguirá la organización en materia de seguridad, así como la estrategia a seguir para la definición de objetivos. La política de seguridad debe ser un documento robusto y a la vez lo suficientemente preciso para que se pueda aplicar de forma horizontal en toda la organización, de tal forma que desde el primero hasta el último pueda cumplirla. A partir de ella, se desarrollará todo el cuerpo normativo y se establecerán los procedimientos acordes a la misma.

La política de seguridad debe establecerse en términos de negocio e identificar las características de la organización. Debe reflejar los objetivos en materia de seguridad de la información, así como reflejar las obligaciones contractuales y legales. La política de seguridad debe estar alineada con la estrategia de gestión de riesgos de la organización y establecer los criterios para la valoración de estos. Finalmente, la política de seguridad debe estar aprobada por la alta dirección como muestra de su patrocinio y compromiso con la seguridad.

El desarrollo de una política de seguridad debe ser un proceso robusto sobre el que se sienten las bases para el éxito de la gestión de la seguridad en la organización.

© Universidad Internacional de La Rioja (UNIR)

6.4. Referencias bibliográficas

Centro Criptológico Nacional. (agosto de 2015). *Guía de Seguridad (CNN-STIC-401). Glosario y abreviaturas.* https://www.ccn-cert.cni.es/pdf/guias/glosario-de-terminos/22-401-descargar-glosario/file.html

INCIBE. Instituto Nacional de Ciberseguridad. (s.f.) *Guías.* https://www.incibe.es/protege-tu-empresa/guias

Foro Económico Mundial. (s.f.). *Informes.* https://es.weforum.org/reports

ENISA.
(s.f.). *Publications.* https://www.enisa.europa.eu/publications#c3=2012&c3=2022&c3=false&c5=publicationDate&reversed=on&b_start=0

ISACA. (s.f.). *Featured publications.* https://www.isaca.org/resources/it-risk

© Universidad Internacional de La Rioja (UNIR)

Ciberseguridad. Una estrategia informático/militar

Corletti, A, (2017). Ciberseguridad. Una estrategia informático/militar. https://www.ieee.es/Galerias/fichero/OtrasPublicaciones/Nacional/2018/Libro-Ciberseguridad_A.Corletti_nov2017.pd.pdf

Una de las principales necesidades que tenemos los seres humanos es la seguridad.

Hace unos 40 años, la tecnología de la información trajo consigo la introducción de la seguridad informática con el objetivo de proteger los sistemas tecnológicos que utilizamos. Después, este concepto se fue transformando en la seguridad de la información con el objetivo de proteger la información. Y más recientemente, comenzamos a hablar de ciberseguridad.

La ciberseguridad incluye una serie de estrategias, metodologías y tecnologías para protegernos de las amenazas actuales y es un nuevo punto de partida para lo que vendrá en el futuro.

Muchas de estas amenazas están llegando al borde la ciberguerra y con este concepto se suma a la ciberseguridad un nuevo jugador que hasta ahora venía mirando de costado: el entorno militar.

Este libro recorre la problemática actual a la cual nos estamos enfrentando y describe claramente conceptos, metodologías, herramientas e ideas que ayudarán al lector a estar más preparado para prevenir y contener nuevas amenazas.

© Universidad Internacional de La Rioja (UNIR)

Ciberriesgos: un acercamiento desde la perspectiva del gestor de riesgos

García, J. M. y Latorre, S. (2021). Actuarios (48), 42-43. https://documentacion.fundacionmapfre.org/documentacion/publico/es/bib/175816.do?queryId=198906&position=12&

Seguramente todos estamos más o menos familiarizados con el término *phishing* o *spyware* dentro de la categoría de delitos digitales *(malware)* y en alguna ocasión habremos oído hablar de los troyanos o los gusanos, lo cual nos da la falsa sensación de que tenemos cierto conocimiento sobre la materia, pero no hay nada como intentar profundizar un poco para ser consciente de tus limitaciones. No es solo el descubrimiento del elenco de términos que puede haber detrás de un ciberataque, sino los matices que los diferencian y que en definitiva determinan a qué tipo de riesgo nos estamos enfrentando y cómo gestionarlo.

© Universidad Internacional de La Rioja (UNIR)

Política de seguridad de las TIC (CCN-STIC 001)

Centro Criptológico Nacional (CCN). (2016). *Política de seguridad de las TIC (CCN-STIC 001).* https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/1579-ccn-stic-001-informacion-clasificada-en-la-administracion/file.html

La dependencia que las empresas tienen de sus sistemas informáticos, además de la complejidad de estos sistemas, produce una creciente preocupación por su seguridad y funcionamiento continuo, con los que quedar a salvo de errores e intromisiones. También, la protección de datos de terceras personas, clientes y empleados, contenidos en las bases de datos, está en el punto de mira de los controles para salvaguardar su privacidad y mantenerlos libres de intromisiones o pérdidas de información a favor de terceros. Todo lo anterior implica establecer una serie de medidas que garanticen que los sistemas informáticos se encuentran perfectamente protegidos frente a interrupción de los servicios

© Universidad Internacional de La Rioja (UNIR)

Glosario de términos de ciberseguridad: una guía de aproximación para el empresario

INCIBE. (2021). *Glosario de términos de ciberseguridad: una guía de aproximación para el empresario.* https://www.incibe.es/protege-tu-empresa/guias/glosario-terminos-ciberseguridad-guia-aproximacion-el-empresario

En el mundo de la ciberseguridad se emplean términos y acrónimos de perfil técnico, que no se usan en el día a día de nuestro lenguaje, y en el caso de personas que no se dedican al ámbito de la ciberseguridad, pueden complicar la comprensión de un artículo o guía. En esta guía, publicada por INCIBE, se definen diferentes términos comúnmente utilizados en las guías, avisos de seguridad y artículos del que ayudan a comprender de forma concisa el contexto de cada término.

© Universidad Internacional de La Rioja (UNIR)

Managing Cyber Risk: A Handbook for UK Boards of Directors

Clinton, L. y Barrack, S. (2017). *Managing Cyber Risk: a handbook of UK boards of directors*. Internet security Alliance. https://www.aig.co.uk/content/dam/aig/emea/united-kingdom/documents/Insights/cyberrisk-directors-handbook.pdf

Este manual fue elaborado por Internet Security Alliance en función de los siguientes cinco principios:

- Los directores deben comprender y abordar la ciberseguridad como un problema de gestión de riesgos en toda la empresa, no solo como un problema de TI.
- Los directores deben comprender las implicaciones legales de los ciberriesgos en relación con las circunstancias específicas de su empresa.
- El Consejo de Administración debe tener acceso a información y conocimientos adecuados en ciberseguridad y las deliberaciones sobre la gestión del riesgo cibernético deben formar parte de las agendas de las reuniones de la junta.
- Los directores deben asegurarse de establecer un marco de gestión de los ciberriesgos para toda la empresa, con personal y presupuesto adecuados.
- Las deliberaciones del Consejo de Administración sobre los ciberriesgos deben incluir la identificación de qué riesgos evitar, cuáles aceptar y cuáles mitigar o transferir a través de un seguro, así como planes específicos asociados con cada enfoque.

© Universidad Internacional de La Rioja (UNIR)

1. Las dimensiones de la seguridad son:

   A. Confidencialidad, integridad, disponibilidad, no repudio y privacidad.

   B. Confidencialidad, integridad, disponibilidad, protección y trazabilidad

   C. Confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad.

   D. Confidencialidad, privacidad, disponibilidad, autenticidad y cumplimiento.

2. ¿Cuándo se debe proteger la información?

   A. Desde el momento en el que el dato entra en el sistema, hasta el momento en que deja de ser útil.

   B. Desde el momento en el que el dato entra en el sistema hasta que se procesa.

   C. Durante la transmisión y utilización de la información.

   D. Durante el proceso, transmisión y utilización.

3. El análisis y gestión de los riesgos:

   A. Permite identificar los riesgos que le podrían impedir lograr sus objetivos de negocio.

   B. Permite identificar los riesgos que le podrían impedir lograr sus objetivos de negocio.

   C. Intenta que los criterios en los que se apoya la seguridad sean más objetivos.

   D. Todas son verdaderas.

© Universidad Internacional de La Rioja (UNIR)

4. ¿Cómo debe protegerse la información?

A. Por medio de la implantación de salvaguardas.

B. Estableciendo procedimientos que permitan una recuperación rápida de los daños sufridos.

C. Minimizando la probabilidad de la materialización de una amenaza.

D. Disminuyendo el impacto en la organización.

Deben contrarrestarse todas las amenazas a las que está expuesta la información de una organización, por medio de la implantación de salvaguardas (controles) que pueden actuar de diferentes maneras.

5. Una política de seguridad debe:

A. Establecerse en términos de negocio.

B. Identificar las características de la organización.

C. Reflejar las obligaciones contractuales y legales.

D. Todas son ciertas.

6. La gestión de riesgos no tiene como objetivo:

A. Formar parte de la toma de decisiones.

B. Integrar factores humanos y culturales.

C. Tratar explícitamente la certidumbre.

D. Ser adaptable.

La gestión de riesgos tiene como objetivo gestionar o tratar el riesgo hasta disminuir el riesgo residual a los niveles asumibles por la dirección y debe tratar explícitamente la incertidumbre.

© Universidad Internacional de La Rioja (UNIR)

7. Por *acceso,* se entiende:

A. La garantía de la identidad del usuario que accede a una información.

B. La garantía de que en todo momento se podrá determinar quién hizo qué y en qué momento lo hizo.

C. la garantía de que la información es accesible en el momento en el que los usuarios autorizados (personas, organizaciones o procesos) tienen necesidad de acceder a ella.

D. La capacidad de poder utilizar los recursos de los sistemas de información y comunicaciones que nos permiten acceder a la información.

8. La gestión de riesgos tiene como objetivo gestionar o tratar el riesgo hasta:

A. Alcanzar el nivel de riesgo aceptable por las partes interesadas.

B. Disminuir el riesgo inherente a los niveles asumibles por la dirección

C. Disminuir el riesgo residual a los niveles asumibles por la dirección.

D. Alcanzar los objetivos de negocio.

9. Es la garantía de que la información no es conocida por personas, organizaciones o procesos que no disponen de la autorización necesaria:

A. Acceso

B. Disponibilidad.

C. Confidencialidad

D. Privacidad.

© Universidad Internacional de La Rioja (UNIR)

10. Es la garantía de que la información es accesible en el momento en el que los usuarios autorizados (personas, organizaciones o procesos) tienen necesidad de acceder a ella.

A. Acceso.

B. Disponibilidad.

C. Confidencialidad.

D. Privacidad.

© Universidad Internacional de La Rioja (UNIR)